

Lab Exercise - Lecture 2

Detect Malicious File using FIM with VirusTotal Integration

Duration: 45–60 minutes — Instructor: Hari — Phase 1

Scenario

An organisation has deployed **Wazuh** on a Linux endpoint (**User Machine**) to monitor user activity and prevent malware infections.

The security team has configured **File Integrity Monitoring (FIM)** to continuously monitor the directory:

`/home/user/Downloads`

This is because users frequently download files from the internet, which may include malicious content.

To enhance detection, Wazuh is integrated with **VirusTotal**. Whenever a new file appears in the Downloads folder:

- Wazuh detects the file creation.
- Generates a cryptographic file hash (MD5/SHA256).
- Sends the hash to VirusTotal for reputation analysis.

One day, a user downloads a file from an external website, and Wazuh generates an alert indicating that the file hash is flagged as **malicious**.

Objective

By the end of this lab, you will:

- Download a file into `/home/user/Downloads` and trigger a FIM event.
- Observe the FIM alert generated by Wazuh in the Dashboard.
- Inspect the alert details including the file hash information.
- Verify the VirusTotal enrichment results for the downloaded file.
- Determine whether the downloaded file is safe or malicious based on the VirusTotal report.

Prerequisites

- Wazuh Manager already deployed (provided by instructor).
- One Ubuntu 22.04 VM per student (User Machine) with Wazuh agent installed and active.
- FIM configured to monitor `/home/user/Downloads` (pre-configured by instructor).
- VirusTotal API key integrated with the Wazuh Manager (pre-configured by instructor).
- Network connectivity between the User Machine, Wazuh Manager, and the internet (for VirusTotal lookups).
- Browser access to the Wazuh Dashboard URL.

Lab Environment

Component	Details
Wazuh Manager IP	<provided by instructor>
Dashboard URL	<code>https://<manager-ip>:443</code>
Dashboard Username	admin
Dashboard Password	<provided by instructor>
User Machine IP	<your assigned IP>
Monitored Directory	<code>/home/user/Downloads</code>
VirusTotal API	Pre-configured on Wazuh Manager

Task

Perform the following steps:

1. Download any file into `/home/user/Downloads`.
2. Observe the FIM alert generated by Wazuh.
3. Check the alert details for file hash information.
4. Verify the VirusTotal enrichment results.
5. Identify whether the downloaded file is safe or malicious.

Task 1 - Verify FIM Configuration on the User Machine (10 min)

Step 1.1 - Confirm FIM is monitoring the Downloads directory

On the **User Machine**, inspect the Wazuh agent configuration to verify FIM is watching the correct path:

```
sudo cat /var/ossec/etc/ossec.conf | grep -A 5 "syscheck"
```

Listing 1: Check FIM configuration

Ensure you can see a `<directories>` block that includes the Downloads path, similar to:

```
<syscheck>
  <frequency>300</frequency>
  <directories check_all="yes" realtime="yes" report_changes="yes">
    /home/user/Downloads
  </directories>
</syscheck>
```

Listing 2: Expected FIM syscheck block

The `realtime="yes"` attribute enables immediate detection of new or modified files using kernel-level inotify events, rather than waiting for the next scheduled scan. The `check_all="yes"` attribute instructs Wazuh to compute and store the file's MD5, SHA1, and SHA256 hashes along with permissions, ownership, and size.

Step 1.2 - Confirm the VirusTotal integration is active

On the **Wazuh Manager** (or ask the instructor to verify), the VirusTotal integration should be present in `ossec.conf`:

```
<integration>
  <name>virustotal</name>
  <api_key><YOUR_VIRUSTOTAL_API_KEY></api_key>
  <rule_id>554,550</rule_id>
  <alert_format>json</alert_format>
</integration>
```

Listing 3: Expected VirusTotal integration block

The FIM `<directories>` block should list `/home/user/Downloads` with `realtime="yes"`. The VirusTotal integration block should be present in the Wazuh Manager configuration. If either is missing, notify the instructor before proceeding.

Task 2 - Download a File and Trigger a FIM Alert (10 min)

Perform the following steps on the **User Machine**.

Step 2.1 - Navigate to the monitored directory

```
cd /home/user/Downloads
```

Listing 4: Switch to the Downloads directory

Step 2.2 - Download a test file

Use `wget` or `curl` to download any publicly accessible file. Your instructor will provide a specific URL for this exercise. An example using a generic test file is shown below:

```
wget -O testfile.exe <URL_PROVIDED_BY_INSTRUCTOR>
```

Listing 5: Download a file into the monitored directory

Alternatively, you can copy an existing file into the directory to simulate a file creation event:

```
cp /usr/bin/ls /home/user/Downloads/testbinary
```

Listing 6: Copy a file to trigger FIM

Since FIM is configured with `realtime="yes"`, Wazuh will detect the new file almost immediately using inotify. You do not need to wait for the scheduled scan interval.

Step 2.3 - Verify the file exists

```
ls -lh /home/user/Downloads/
```

Listing 7: List files in Downloads directory

The downloaded or copied file should appear in the directory listing. Within 30–60 seconds, a FIM alert should be visible in the Wazuh Dashboard.

Task 3 - Observe the FIM Alert in the Wazuh Dashboard (10 min)

Perform the following steps in your **browser** on the Wazuh Dashboard.

Step 3.1 - Navigate to Security Events

1. Log into the Dashboard at `https://<manager-ip>:443`.
2. In the left sidebar, click **Security Events**.
3. Filter events by your agent name or User Machine IP.

Step 3.2 - Identify the FIM alert

1. Look for alerts with **Rule ID 554** (*File added to the system*) or **Rule ID 550** (*Integrity checksum changed*).
2. Click on one alert to expand the full event details.
3. Locate the following fields in the alert JSON:
 - `syscheck.path` — full path of the detected file.
 - `syscheck.md5_after` — MD5 hash of the file.
 - `syscheck.sha256_after` — SHA256 hash of the file.
 - `syscheck.event` — type of event (e.g., `added`).
4. Note the hash values; these will be sent to VirusTotal for analysis.

You should see a FIM alert for the file you placed in `/home/user/Downloads`. The alert JSON must contain MD5 and SHA256 hash fields. Record these values for reference in the next task.

Task 4 - Verify the VirusTotal Enrichment Results (10 min)

Step 4.1 - Locate the VirusTotal alert

After the FIM alert is generated, the Wazuh Manager automatically submits the file hash to VirusTotal. A secondary alert is generated with the enrichment results. In the **Security Events** view:

1. Filter for **Rule ID 87105** (*VirusTotal: Alert - No positives found*) or **Rule ID 87101** (*VirusTotal: Alert - X engines detected this file*).
2. Click the alert to expand the full details.

Step 4.2 - Inspect the VirusTotal enrichment fields

Within the alert, examine the following fields:

Field	Description
<code>virustotal.positives</code>	Number of AV engines that flagged the file
<code>virustotal.total</code>	Total number of AV engines that scanned the file
<code>virustotal.permalink</code>	Direct link to the full VirusTotal report
<code>virustotal.scan_date</code>	Timestamp of the most recent VirusTotal scan
<code>virustotal.description</code>	Wazuh-generated verdict summary

Step 4.3 - Open the VirusTotal report

Copy the URL from the `virustotal.permalink` field and open it in your browser to view the full scan report, including which specific AV engines flagged the file and the assigned malware family name (if any).

```
# You can also query VirusTotal manually using curl with your API key
curl -s "https://www.virustotal.com/api/v3/files/<SHA256_HASH>" \
-H "x-apikey: <YOUR_API_KEY>" | python3 -m json.tool | grep -E \
"last_analysis_stats|meaningful_name|type_description"
```

Listing 8: Manually query VirusTotal (optional)

The VirusTotal enrichment alert should be visible in the Wazuh Dashboard. The `virustotal.positives` field indicates how many engines detected a threat. A value greater than 0 means at least one engine flagged the file as malicious.

Task 5 - Identify Whether the File is Safe or Malicious (5 min)

Step 5.1 - Interpret the VirusTotal verdict

Use the following table to interpret the `virustotal.positives` value from your alert:

Positives	Classification	Recommended Action
0	Clean / Safe	File is likely safe; monitor for further activity
1-3	Suspicious	Investigate further; may be a false positive
4 or more	Malicious	Quarantine or delete the file immediately

Step 5.2 - Record your findings

On the **User Machine**, compute the file hash locally and compare it with the value reported in the Wazuh alert to confirm they match:

```
md5sum /home/user/Downloads/testfile.exe
sha256sum /home/user/Downloads/testfile.exe
```

Listing 9: Compute file hashes locally

The locally computed hashes should exactly match the `syscheck.md5_after` and `syscheck.sha256_after` values in the Wazuh FIM alert. A mismatch would indicate that the file was modified after being detected, which is itself a security concern.

Reflection Questions

Answer these in your own words (2–3 sentences each):

- Q1.** What is the purpose of File Integrity Monitoring (FIM) in Wazuh? How does it differ from a traditional antivirus solution running on the endpoint?
- Q2.** The VirusTotal integration submits file hashes rather than the files themselves. What are the privacy and security implications of this approach? Under what circumstances might hash-based lookups produce false negatives?
- Q3.** If a newly created malware sample has never been submitted to VirusTotal before, what would the `virustotal.positives` value be, and how could you complement FIM and VirusTotal to detect such zero-day threats?

Submission

- Screenshot of the terminal showing the file successfully downloaded or copied into `/home/user/Downloads`.
- Screenshot of the Wazuh Dashboard showing the **FIM alert** (Rule ID 554 or 550) with the file path and hash fields visible.
- Screenshot of the **VirusTotal enrichment alert** in the Dashboard showing the `virustotal.positives` and `virustotal.total` fields.
- Screenshot of the full VirusTotal report page (opened via the `permalink` field) showing the AV engine scan results.
- Screenshot of the terminal showing the locally computed MD5 and SHA256 hashes matching the alert values.
- Written answers to the three reflection questions.